



SECURE DEVELOPMENT

Secure Software Development Practices Policy

Lightweight SSDP for a small founder-written Next.js dashboard. No formal threat modeling, SAST, or staged deployment pipeline.

Masar Zero is not a software company. We have a small founder-written Next.js dashboard on Vercel. This policy documents our lightweight development practices: pinned dependencies, GitHub Dependabot, informal founder code review, and Vercel deployment protection. No formal SSDLC program, SAST tooling, or staged deployment pipeline.

PREPARED BY	Masar Zero W.L.L.
DOCUMENT ID	MZ-POL-009
VERSION	v1.0
EFFECTIVE	12 July 2026
CLASSIFICATION	Internal Use — Authorized Recipients Only

Document Control

Document ID	MZ-POL-009	Version	v1.0
Effective Date	12 July 2026	Review Cycle	Annual (next review: July 2027)
Document Owner	Hari Krishna	Classification	Internal Use
Publisher	Masar Zero W.L.L.	Contact	hari@masarzero.com

Revision History

Version	Date	Author	Summary of Change
v1.0	12 July 2026	Masar Zero	Initial release of Secure Software Development Practices Policy.

Approval

This document is prepared by Hari Krishna and approved by Dr. A. Latif Alkhaja, Chairman of Masar Zero W.L.L. It is effective as of the date shown above and is reviewed annually or upon significant change per MZ-POL-001 §7. Distribution is restricted to authorized recipients; redistribution requires written approval from Masar Zero leadership.

Role	Name	Signature	Date
Prepared by	Hari Krishna		
Approved by	Dr. A. Latif Alkhaja (Chairman)		

1. Purpose & Scope

This policy defines the secure software development practices Masar Zero W.L.L. applies to the small amount of custom code it maintains. It applies to: (a) the Masar Zero operator dashboard (a Next.js application hosted on Vercel, founder-written); (b) the Supabase schema migrations; (c) any infrastructure-as-code (Terraform, etc.) used to configure Masar Zero cloud resources.

Honest scope statement. Masar Zero is not a software company. We have a small founder-written Next.js dashboard. We do not operate a formal SSDLC program, threat modeling process, SAST tooling, secret scanning, staged deployment pipeline, or 14-day post-deployment monitoring period. This policy describes the lightweight practices we do follow.

2. Source Code Management

All Masar Zero source code is hosted in a private GitHub repository. Founder accounts require 2FA. The main branch is protected: direct pushes are not allowed; pull requests require at least one founder review. Dependencies are pinned by hash in package-lock.json.

3. Dependency Management

Third-party npm dependencies are managed to minimize supply-chain risk:

- All dependencies pinned in package-lock.json (npm ci for reproducible installs).
- GitHub Dependabot enabled on the repository; opens PRs for vulnerable dependencies.
- Founders review and merge Dependabot PRs within 7 days for high-severity alerts, 30 days for medium.
- No new dependency may be added without a founder reviewing: license (only OSI-approved), maintainer reputation, last publish date, download volume, and known vulnerabilities.

4. Code Review

All code changes require a pull request reviewed by at least one founder other than the author. The reviewer verifies: (a) the change does what it claims; (b) no secrets are committed; (c) no obvious security issues (SQL injection, XSS, insecure crypto). There is no formal SAST tooling; review is manual.

5. Deployment

Code is deployed to Vercel directly from the main branch on merge. Vercel provides instant rollback if any regression is detected. There is no separate staging environment by default; founders test locally before merging. For changes that touch authentication, authorization, or the Supabase schema, founders manually verify in the Vercel preview deployment before merging to main.

Environment variables (subprocessor API keys, etc.) are stored in Vercel as encrypted secrets, scoped per environment (production, preview, development). Production secrets are never in preview or development environments.

6. What Masar Zero Does Not Do

For transparency, the following SSDLC practices are **not** in place at Masar Zero:

- No formal threat modeling (STRIDE or otherwise).
- No SAST tooling (e.g., Semgrep, Snyk Code).
- No secret scanning beyond GitHub's built-in push protection.
- No staged deployment pipeline (dev → staging → prod).
- No 14-day post-deployment monitoring period.
- No formal change ticket process.
- No OWASP ASVS L2 verification.

Masar Zero may adopt some of these practices as the dashboard grows in complexity. For now, the lightweight approach is proportionate to the small codebase size.

7. References

- MZ-POL-001 — Governance Program
- MZ-POL-005 — Vulnerability & Patch Management (covers dependency patching)
- GitHub Dependabot — <https://docs.github.com/en/code-security/dependabot>
- Vercel Deployment Protection — <https://vercel.com/docs/deployments/preview-deployments>

MZ-POL-009 — *Secure Software Development Practices Policy. End of document.*